
Informe Profesional de Pentesting

Actividad A08 — Hacking Ético

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Contratista: **Uriel Martín Cabrera** — Username THM: urimartincabrera123

Ciclo Académico Vigente

Índice

1. Datos generales	2
2. Pre-pentesting	2
3. Durante: Hallazgos por fase	3
4. Resumen ejecutivo de hallazgos	4
5. Post-pentesting: Recomendaciones	4
6. Protocolo de Contingencia	4
7. Anexos	5

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno)	Uriel Martín Cabrera
DNI	44404719
Username TryHackMe	urimartincabrera123
Email institucional	cabrerauriel@uch.edu.ar
Sala de elección (Nivel 2)	Blue (Windows — EternalBlue, MS17-010)
Branch en GitHub	cabrera-uriel
Fecha de inicio	2026-10-07
Fecha de cierre	[COMPLETAR]

2. Pre-pentesting

Alcance del trabajo

Dentro del alcance: exclusivamente las máquinas de laboratorio asignadas en la plataforma TryHackMe correspondientes al núcleo obligatorio (*Pentesting Fundamentals* y *Basic Pentesting*) y a la sala de Nivel 2 seleccionada, **Blue** (entorno Windows, explotación de SMBv1 / MS17-010). El trabajo se realiza sobre la dirección IP que TryHackMe asigna dinámicamente a cada sala, a través de la VPN oficial de la plataforma (interfaz `tun0`).

Fuera del alcance: cualquier sistema real, de producción o de terceros; la infraestructura de la Facultad; direcciones IP distintas a la asignada por TryHackMe; ataques de denegación de servicio (DoS); ingeniería social sobre personas reales; y toda técnica que exceda lo estrictamente necesario para evidenciar cada hallazgo.

Reglas de Enfrentamiento (ROE)

- **Ventana de trabajo:** durante las sesiones de laboratorio del ciclo académico.
- **Objetivo único:** solo se interactúa con la IP objetivo asignada por THM vía `tun0`.
- **Fuerza bruta acotada:** de usarse (p. ej. Hydra), se limita la concurrencia (`-t 4 -f`) y solo si la sala lo requiere y lo autoriza.
- **Prohibido:** DoS, exfiltración real de datos, y persistencia más allá de lo necesario para la evidencia.
- **Notificación:** ante cualquier comportamiento inesperado o acción potencialmente fuera de alcance, se detiene la prueba y se informa de inmediato al docente.

Autorización

Se declara contar con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para ejecutar las pruebas sobre los entornos de laboratorio de TryHackMe indicados en la guía A08. Todas las actividades se desarrollaron en entornos controlados (sandbox) y con fines exclusivamente académicos.

Metodología utilizada

Se adopta como columna vertebral la guía **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*), por ser un estándar reconocido cuyas fases (planificación, descubrimiento, ataque y reporte) se alinean con el flujo exigido por la actividad. Se complementa con la **OWASP Web Security Testing Guide (WSTG)** para los componentes web y con el enfoque por fases de **PTES** para organizar el trabajo (reconocimiento, escaneo, enumeración, explotación, post-explotación y reporte). La elección responde a que el alcance se limita a entornos de laboratorio controlados, donde priman la trazabilidad metodológica y la reproducibilidad por sobre técnicas intrusivas avanzadas.

3. Durante: Hallazgos por fase

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	[COMPLETAR]
Componente afectado	[COMPLETAR: servicio/puerto/versión]
Categoría (OWASP / CWE)	[COMPLETAR]
CVE (si aplica)	[COMPLETAR]
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/¡fase¿_H-01.png
Herramienta utilizada	[COMPLETAR]
Impacto en la Tríada CIA	☐ Confidencialidad ☐ Integridad ☐ Disponibilidad

Salvaguarda pro- [COMPLETAR]
puesta

Riesgo residual tras ☐ Bajo ☐ Medio ☐ Alto
aplicar

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico		
Alto		
Medio		
Bajo		
Total		

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

[COMPLETAR] Lista priorizada por criticidad. Ejemplos de forma:

- Aplicar el parche [MS/KB o CVE] que corrige la vulnerabilidad en [servicio].
- Deshabilitar protocolos/servicios obsoletos e innecesarios expuestos (p. ej. SMBv1).
- Segmentar la red y restringir el acceso a los puertos sensibles.

Recomendaciones administrativas (políticas y procesos)

[COMPLETAR] Ejemplos: gestión de parches periódica, hardening documentado, capacitación del personal, revisiones de seguridad recurrentes.

6. Protocolo de Contingencia

Escenario de falla

Durante la fase de explotación, el lanzamiento de un exploit o un escaneo agresivo podría degradar o interrumpir el servicio vulnerable objetivo (por ejemplo, el servicio explotado deja de responder o el sistema se reinicia). En un entorno productivo real de INSECUR S.A., esto se traduciría en la indisponibilidad temporal del servicio afectado.

Impacto sobre la continuidad del negocio

El proceso de negocio soportado por [COMPLETAR: servicio afectado] quedaría indisponible durante la ventana de interrupción. Impacto estimado: [COMPLETAR] (p. ej. interrupción del acceso de clientes, detención de operaciones internas) por un período aproximado de [COMPLETAR].

Plan de respuesta

1. **Activación:** el monitoreo (o la pérdida de respuesta del servicio) detecta la caída.
2. **Contención (primeros 15 min):** detener inmediatamente la prueba en curso, aislar el objetivo y registrar hora y último comando ejecutado.
3. **Recuperación:** restaurar desde backup / snapshot o reiniciar el servicio afectado; verificar integridad antes de reponer en servicio.
4. **Comunicación:** notificar a la dirección de INSECUR S.A., a los clientes afectados (si corresponde) y, en el contexto académico, al docente.
5. **Post-mortem:** documentar causa raíz, acciones tomadas y lecciones aprendidas.

RTO y RPO estimados

RTO (Recovery Time Objective): [COMPLETAR, p. ej. 1 hora]

RPO (Recovery Point Objective): [COMPLETAR, p. ej. último backup diario]

7. Anexos**Anexo A — Bitácora de comandos**

Archivos `bitacora/clase_XX_*.txt` incluidos en el branch `cabrera-uriel`.

Anexo B — Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por fase. Cada archivo nombrado como `<fase>_<hallazgoID>.png`.

Anexo C — Hashes de las flags obtenidas

```
1 # Formato: flag_id  sha256_hash
2 H-01  [pegar hash]
3 H-02  [pegar hash]
```

Anexo D — Declaración ética firmada

Yo, **Uriel Martín Cabrera**, DNI 44404719, declaro que todas las actividades descritas en este informe se realizaron dentro del alcance autorizado, en entornos controlados de TryHackMe y con fines exclusivamente académicos.

Firma del estudiante

Fecha

Ética y Legalidad

Esta actividad se desarrolló íntegramente en entornos de laboratorio (sandbox) de TryHackMe, bajo autorización de la cátedra. No se aplicó ninguna técnica sobre sistemas reales.